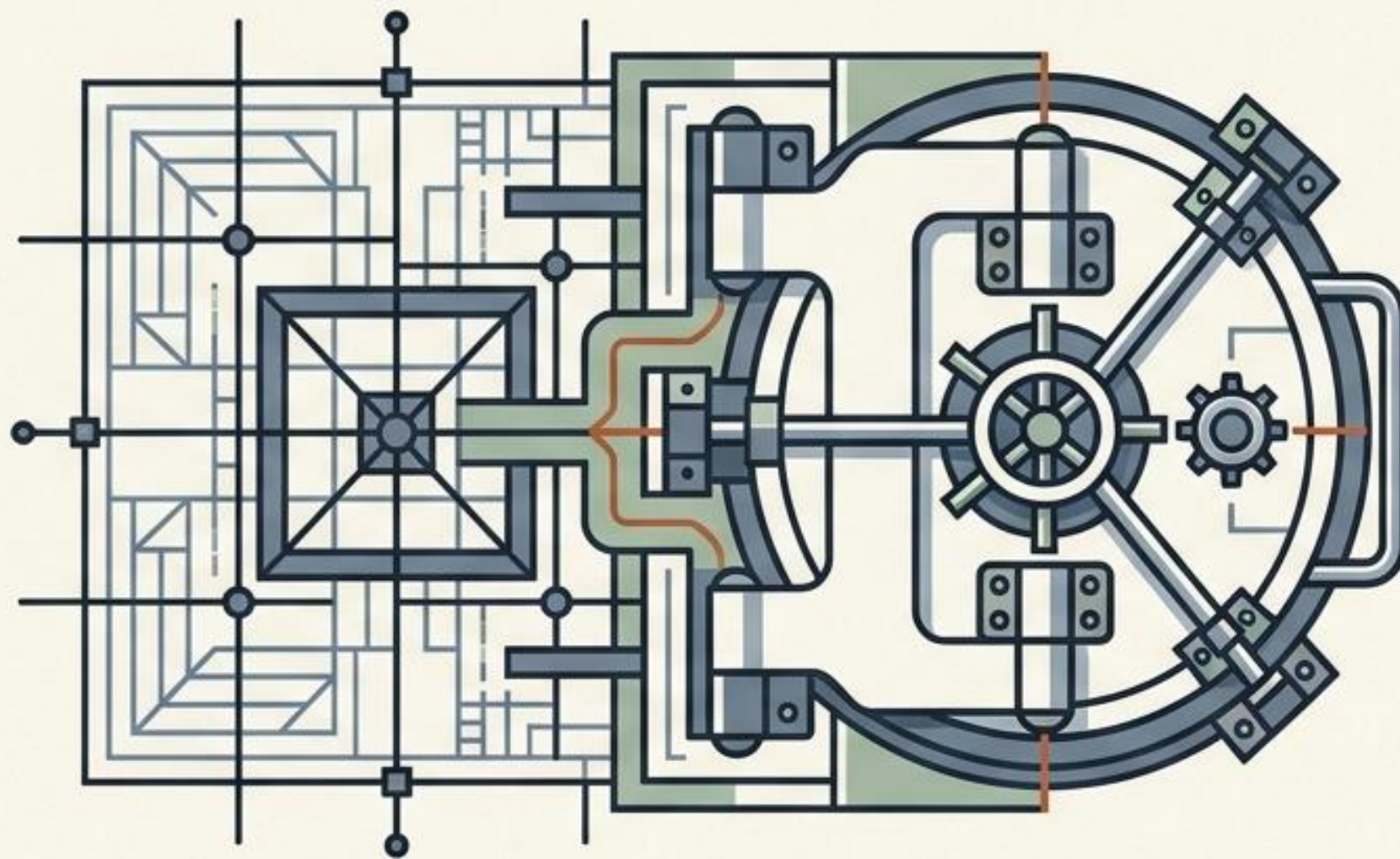


The AAISM™ Exam Playbook

The Definitive Visual Architecture for the ISACA Advanced
in AI Security Management Certification.



DOCUMENT REF:
AAISM-PLAYBOOK-01

Exam Logistics & Prerequisites

The Arena

90

Questions

150

Minutes (1.6 minutes
per question)

Computer-based testing (PSI Centers or Remote)

The Target



Scaled Passing Score.

Evaluates consistent standard of knowledge,
not a raw percentage.

The Gatekeeper



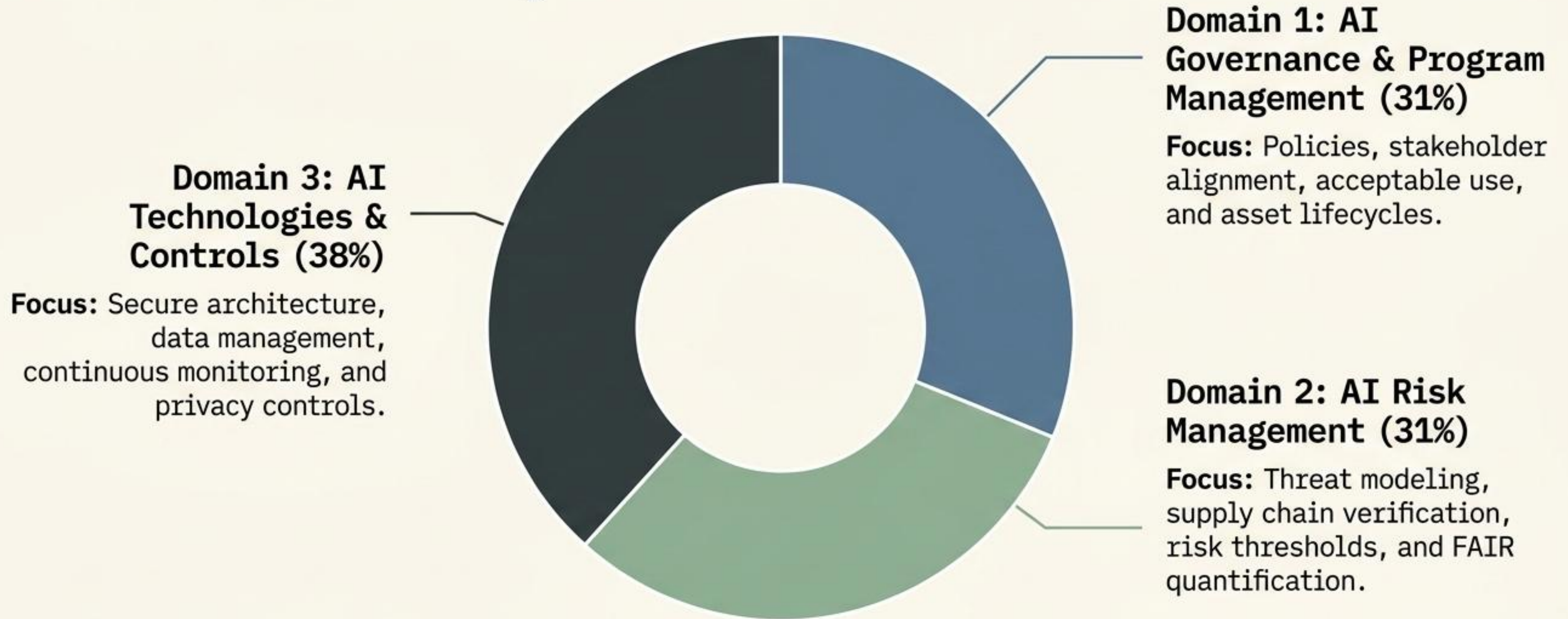
Active CISM or CISSP Required.

Must be active to register and
certify. Validates pre-existing
enterprise governance expertise.

The Maintenance

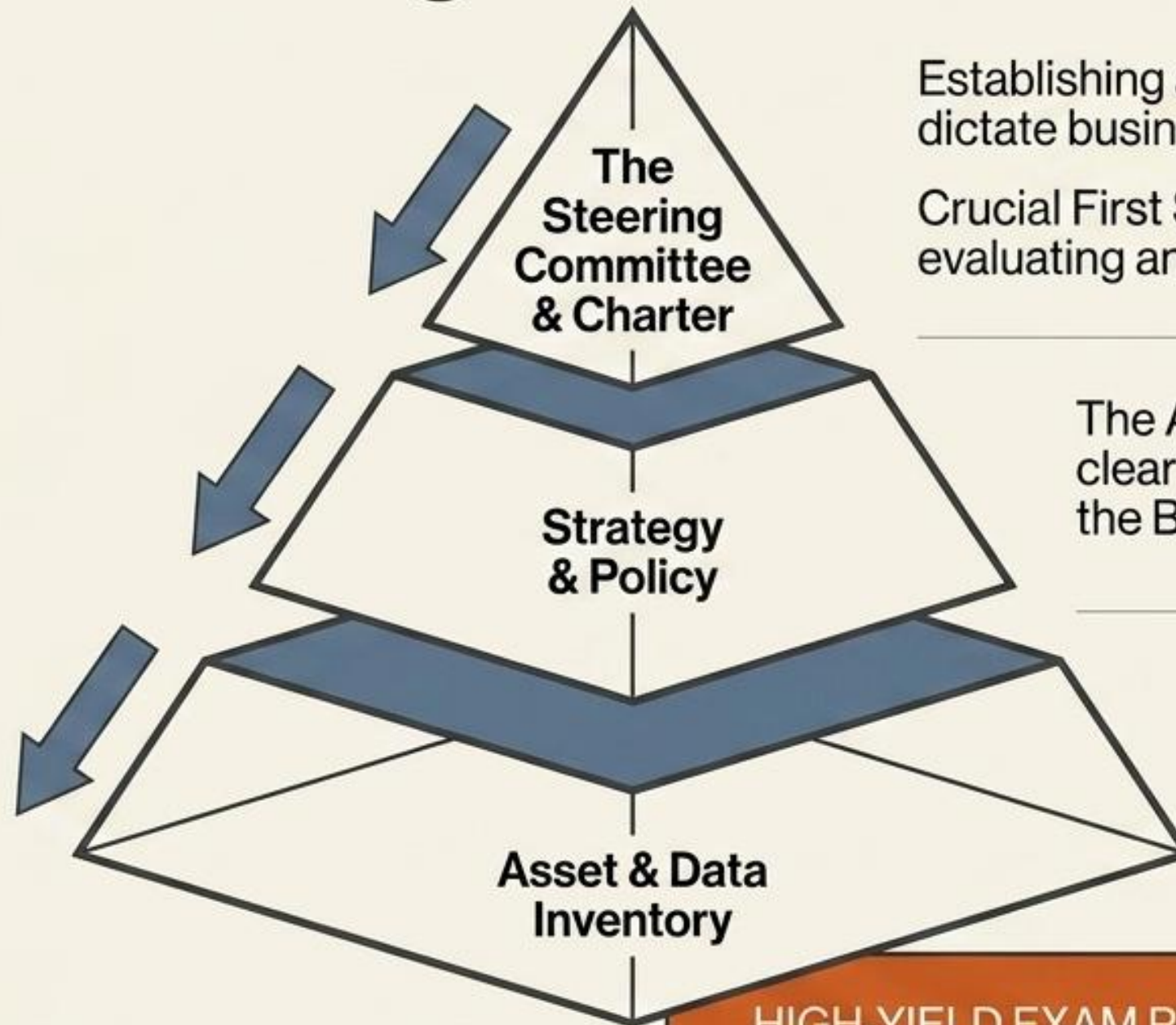
- ✓ 10 AI CPEs required annually (30 over 3 years)
- ✓ \$50 application processing fee
- ✓ Strict adherence to the ISACA Code of Professional Ethics

The Exam Blueprint



Architect's Directive: Think like a strategic leader, not an ML engineer.
The exam tests governance judgment over technical execution.

Domain 1: Governance & Program Management



Establishing a cross-functional AI oversight team to dictate business alignment and risk appetite.

Crucial First Step: Define the business problem before evaluating any technology.

The Acceptable Use Policy (AUP) establishing clear boundaries for GenAI tools, paired with the Build vs. Buy strategic analysis.

Creating a comprehensive catalog of all models, training datasets, and shadow AI.

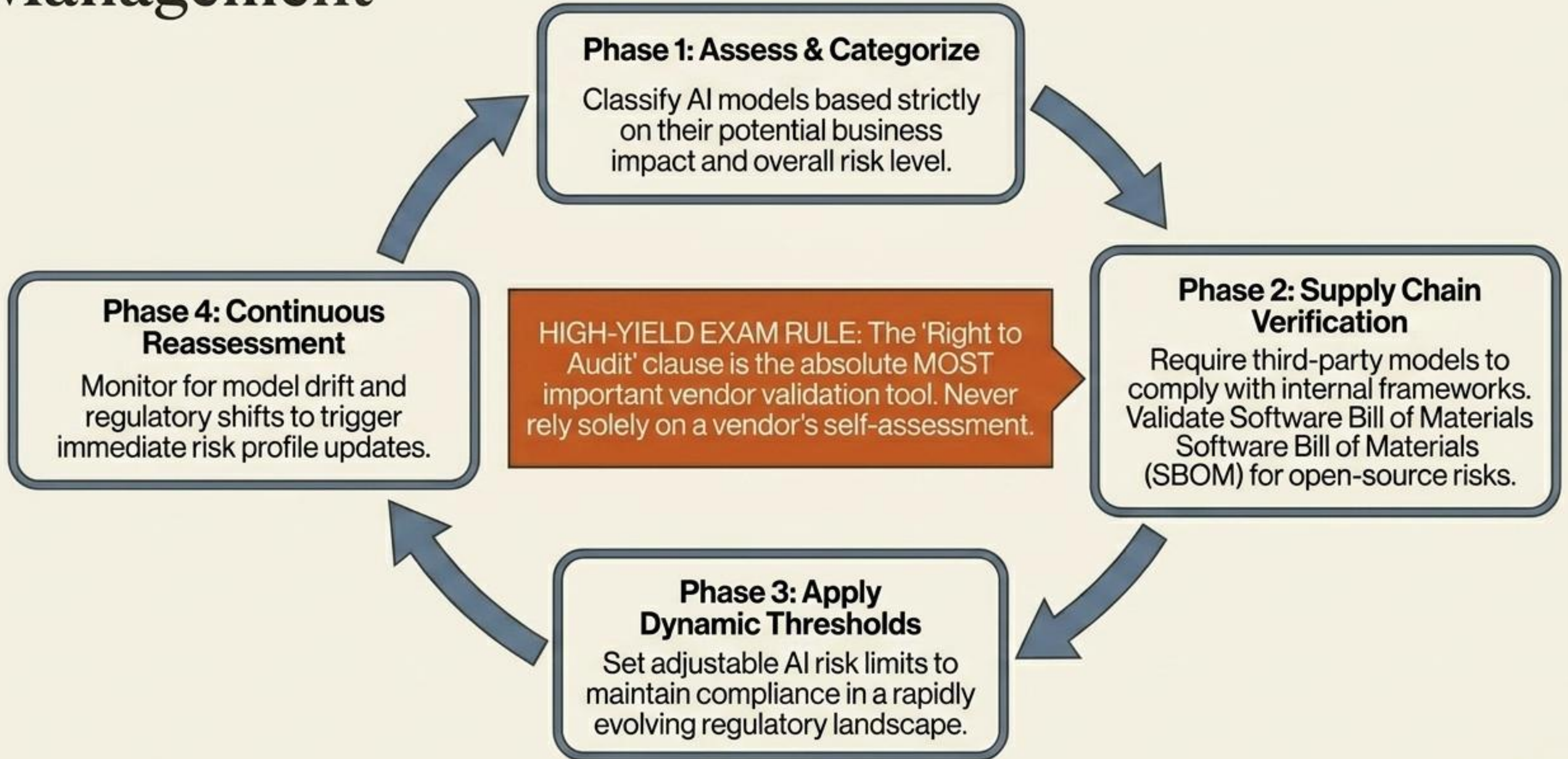
HIGH-YIELD EXAM RULE: You cannot protect or assess what is not in your inventory. When asked for the FIRST step in governance or risk categorization, always secure the enterprise asset inventory.

The Regulatory & Framework Matrix

NIST AI RMF	EU AI Act	Data Privacy (GDPR/CCPA)
• Orientation: Voluntary & Adaptable. • Core Mechanism: Built on four iterative functions (Govern, Map, Measure, Act). • Focus: Fosters trustworthy AI development without strict legal mandates.	• Orientation: Prescriptive & Binding. • Core Mechanism: Categorizes AI by risk levels (unacceptable, high, limited, minimal). • Focus: Imposes strict legal mandates and heavy financial penalties.	• Orientation: Restrictive Constraints. • Core Mechanism: Mandates explicit informed consent and the right to erasure. • Focus: Strict data anonymization requirements when utilizing PII for model training.

STRATEGIC TAKEAWAY: Proactive mapping of internal governance policies to geographical regulations prevents critical compliance failures.

Domain 2: AI Risk Management



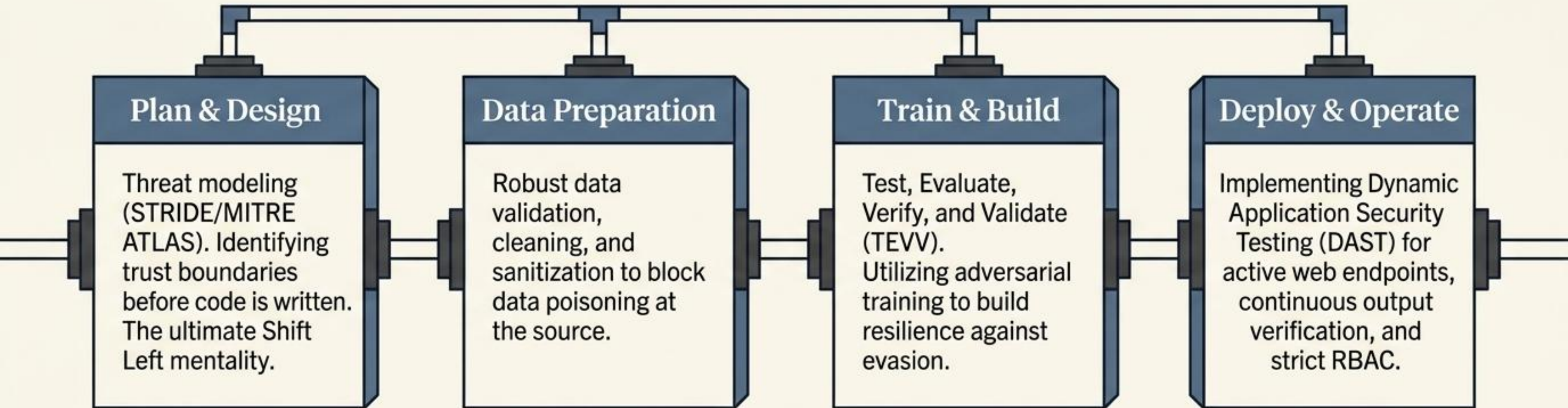
Quantifying & Treating AI Risk

MITIGATE Implement technical controls (e.g., input validation) to reduce the likelihood or impact to acceptable levels.	TRANSFER Shift financial exposure to a third party (e.g., specialized AI cyber liability insurance).
AVOID Cease the high-risk AI operation entirely if it exceeds organizational risk appetite.	ACCEPT Document residual risks and formally accept them via executive sign-off when mitigations cost more than the exposure.

The FAIR Framework Application

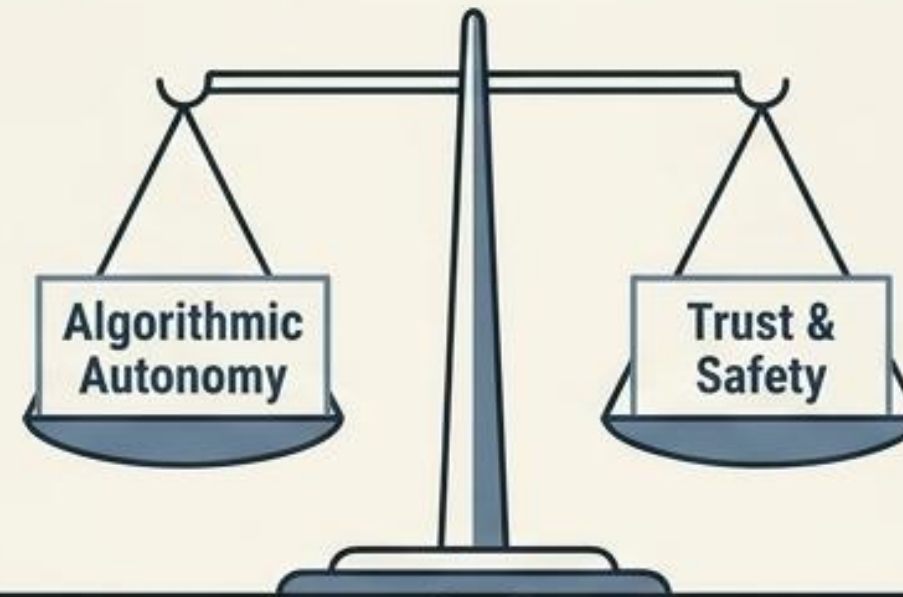
Translating abstract AI vulnerabilities (like algorithmic bias) into concrete, quantifiable financial impacts (e.g., lawsuit costs) so the C-Suite can make informed risk treatment decisions.

Domain 3: AI Technologies & Controls



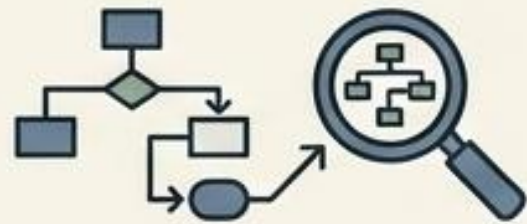
HIGH-YIELD EXAM RULE: Security must be Shifted Left and embedded directly into the design phase. Retrofitting controls onto live AI systems is mathematically and operationally flawed.

The Black Box Problem: Privacy, Ethics, Ethics & Trust



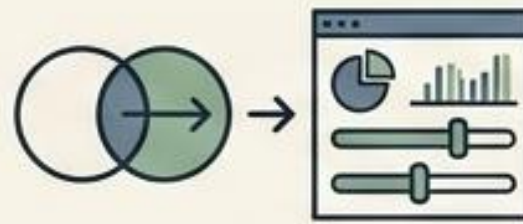
Explainable AI (XAI)

Combating the Black Box by deploying tools that provide traceability and auditability for how a model reached its specific decision. Promotes hiring transparency.



Algorithmic Bias

Addressing systemic prejudice.
The Fix: Retrain the model with balanced data and implement continuous fairness indicator tracking.



The Ultimate Failsafe

For high-consequence environments (e.g., healthcare, finance), the **BEST** control for mitigating hallucination or opaque logic is the **Human-in-the-Loop (HITL)** authorization requirement.



The AI Threat Landscape

Prompt Injection



Manipulating LLM input rules with malicious text to bypass safety guardrails or leak sensitive data.

Data Poisoning



Corrupting or altering the training dataset to fundamentally compromise the model's future integrity.

Evasion Attacks



Tricking an already-trained model with mathematically optimized perturbations (altering input slightly to force a misclassification).

Residual Artifacts



The persistence of API keys, model files, or sensitive training data in decommissioned or abandoned systems.

Threat-to-Control Synthesis Matrix

High-Yield Diagnostic Logic based on official QAE structures.

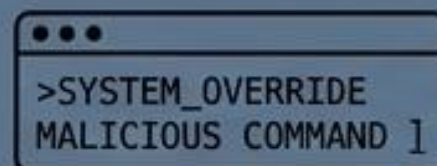
IF: Suspected Data Poisoning



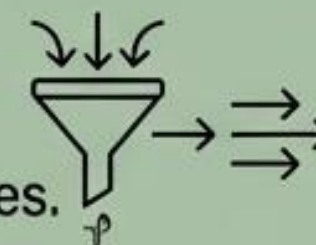
THEN: FIRST step is to isolate the affected dataset to prevent further contamination of the pipeline, followed by robust data validation.



IF: Prompt Injection against an LLM



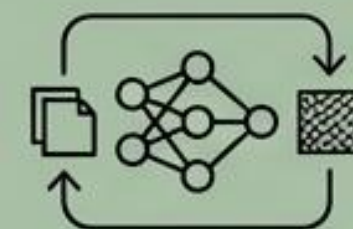
THEN: BEST fix is strict input validation and robust sanitization mechanisms before processing user queries.



IF: Susceptibility to Evasion Attacks



THEN: BEST architectural defense is adversarial training (training the model on actively generated adversarial examples).



IF: Threat of Residual Artifacts



THEN: BEST action is secure decommissioning, rigorous data wiping, and immediate revocation of active service accounts/API keys.



Securing the AI Lifecycle: Operations & Monitoring

Monitoring KPIs & Drift



KPI:
Classification
Error Rates

Use Key Performance Indicators to track Classification Error Rates. An increase signals Model Drift, proving the system is losing business value and requires retraining.

Operational Lineage

Enforce automated versioning and provenance tracking.

If you cannot trace where a model artifact originated or what data it trained on, the system cannot be audited.



PROVENANCE:
Origin -> Training Data -> Model Artifact

AUDIT FAILURE

Incident Response Integration



ACTION:
Isolate System

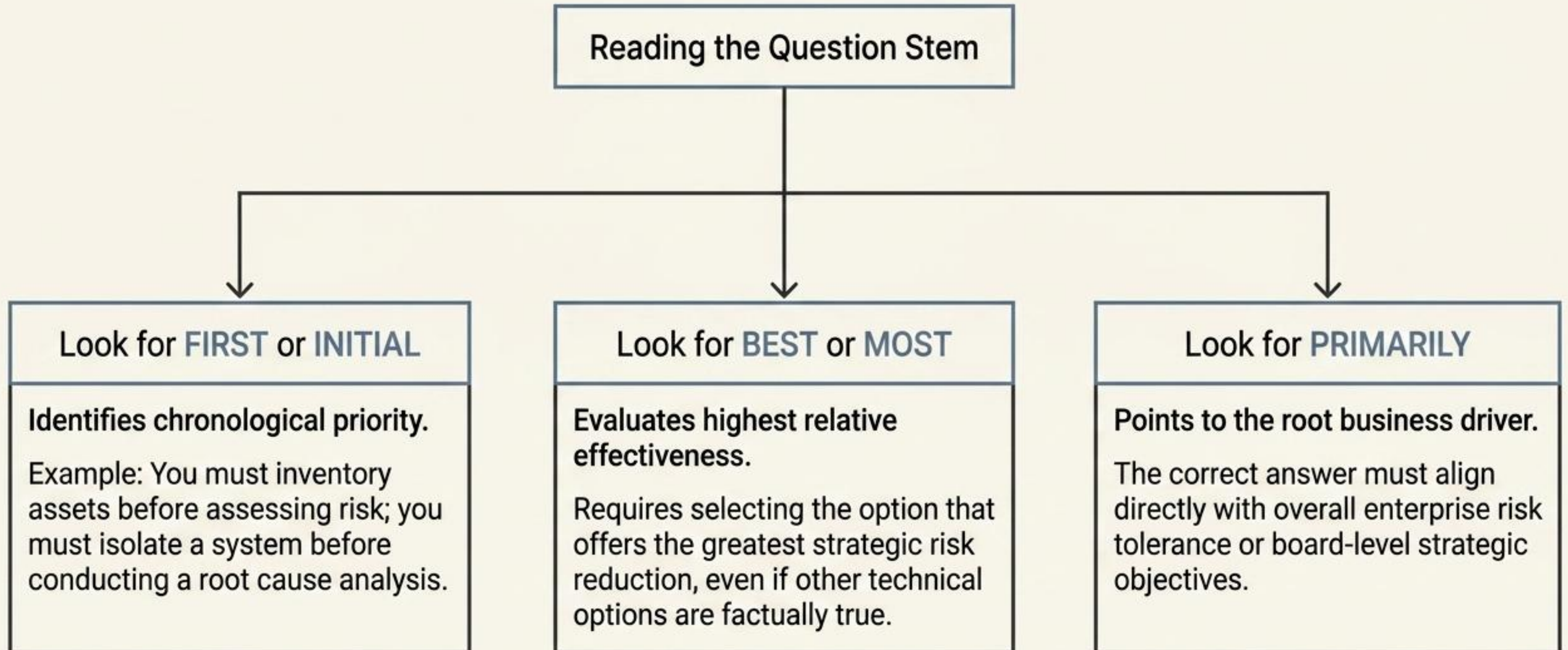
AI Incident Response Plans (AIRPs) must supplement—not replace—the enterprise IRP.

First action in an AI breach (e.g., ransomware hitting a model):
Isolate the infected system from network storage.

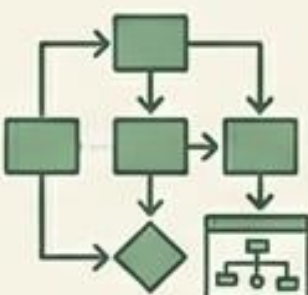


Decoding Scenario Questions

High-Yield Diagnostic Logic based on official QAE structures.



Surviving Cognitive Traps

The Trap	The ISACA Way
 Technical Bias: Picking the most advanced technical solution (e.g., continuous API rotation).	 Governance Focus: Picking the governance-aligned, business-justified solution (e.g., enforcing acceptable use policies).
 Authority Assumption: Assuming the security team inherently owns and accepts AI risk.	 Business Ownership: Recognizing that business stakeholders own the risk; security is advisory and enforces the steering committee's appetite.
 Ambiguity Panic: Freezing or guessing when presented with only partial scenario information.	 Structured Methodology: Defaulting to a formal methodology (e.g., conducting a threat modeling exercise) to gain clarity before acting.

The Exam-Day Battle Plan

Minute 0

The First Pass

Answer the unambiguous questions immediately.

Aggressively flag complex, wordy scenario questions without lingering. Conserve your cognitive energy.

Minute 90

The Physical Reset

Take a requested intermission. Stand up, walk away from the terminal. Reset your cognitive frame to clear exam blindness.



Minute 95

The Second Pass

Return to flagged questions. Hunt for the semantic qualifiers (FIRST, BEST) with fresh eyes and full context.

Minute 150

When stuck between two answers, elevate your perspective. Choose the answer that most directly aligns AI operations with the organization's overarching business goals and approved risk appetite.